

Atacando el Laboratorio de Seguridad OT

GRFICSv3 parte 3

Desarrollado por: Roberto Tejado

Cómo ARP Spoofing (suplantación de ARP) expone el tráfico OT (Demostración de análisis de red HMI)

En esta parte analizaremos el tráfico de red en el sistema de control industrial. Cuando los dispositivos se comunican entre sí a través de una red, solemos pensar que se dirigen mediante su dirección IP. Sin embargo, en realidad, a nivel básico, necesitan conocer la dirección MAC (Control de Acceso al Medio) de cada uno.

La capa 2 de la red, asigna a cada dispositivo su propia dirección MAC (se utiliza direcciones MAC para identificar dispositivos dentro de la red local,). Por lo tanto, existe un esquema que utiliza el protocolo ARP (Protocolo de Resolución de Direcciones) para mapear direcciones IP a direcciones MAC.

El protocolo ARP no cuenta con mecanismos de autenticación integrados, y sin autenticación no se puede verificar la legitimidad de los mensajes ARP. Esto hace que muchas redes sean vulnerables a un tipo de ataque llamado suplantación de identidad ARP o **ARP Spoofing**. La suplantación de ARP permite a un atacante hacerse pasar por otro dispositivo en la red para interceptar los mensajes destinados a dicho dispositivo.

En esta parte, veremos lo fácil que es hacerse pasar por esa interfaz hombre-máquina (HMI) e interceptar el tráfico destinado a ella.

Primero, desde el panel de control del simulador, abre la estación de trabajo del atacante, kali. A continuación, abre una nueva terminal

Para asegurarnos de que estamos realizando la suplantación y el análisis del tráfico en la interfaz de red correcta, ejecuta primero el comando `ifconfig` y luego identifica qué interfaz está conectada a la dirección IP 192.168.90.107.

```
ifconfig
```

```
(kali@kali)-[~]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 172.18.0.8 netmask 255.255.0.0 broadcast 172.18.255.255
    ether c2:ae:69:f8:5a:68 txqueuelen 0 (Ethernet)
    RX packets 260139 bytes 24446442 (23.3 MiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 376442 bytes 227597644 (217.0 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

eth1: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.90.6 netmask 255.255.255.0 broadcast 192.168.90.255
    ether 2a:6d:a7:ef:95:8f txqueuelen 0 (Ethernet)
    RX packets 44303 bytes 95538414 (91.1 MiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 53754 bytes 13496847 (12.8 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 790799 bytes 242798646 (231.5 MiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 790799 bytes 242798646 (231.5 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

El comando para ejecutar un ataque de suplantación de ARP(ARP Spoofing) se llama simplemente 'arp spoof' y normalmente requiere privilegios de administrador para funcionar correctamente. Escribe `sudo arpspoof` seguido de un guion `i` y luego el nombre de la interfaz de red correspondiente que acabamos de encontrar, `eth1` en mi caso. Después, escribe la dirección IP que quieres suplantar. Usamos `192.168.90.107`, que es la dirección IP que probablemente pertenece a la interfaz hombre-máquina o HMI.

```
sudo arpspoof -i eth1 192.168.90.107
```

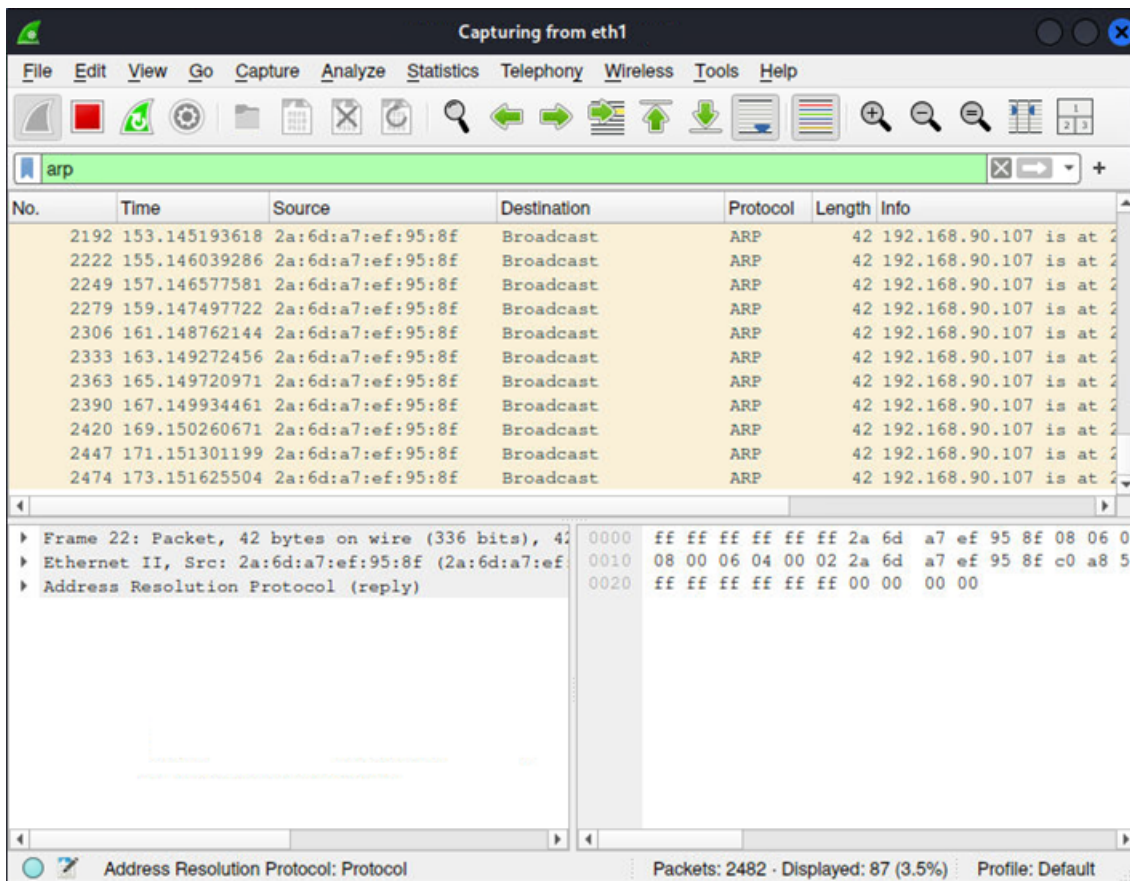
Ahora que vamos a simular estar en esta dirección IP, deberíamos poder capturar el tráfico que entra y sale de ella. Una excelente herramienta para capturar tráfico es Wireshark, que viene integrada en Kali. Abre una nueva terminal y ejecuta:

```
sudo wireshark
```

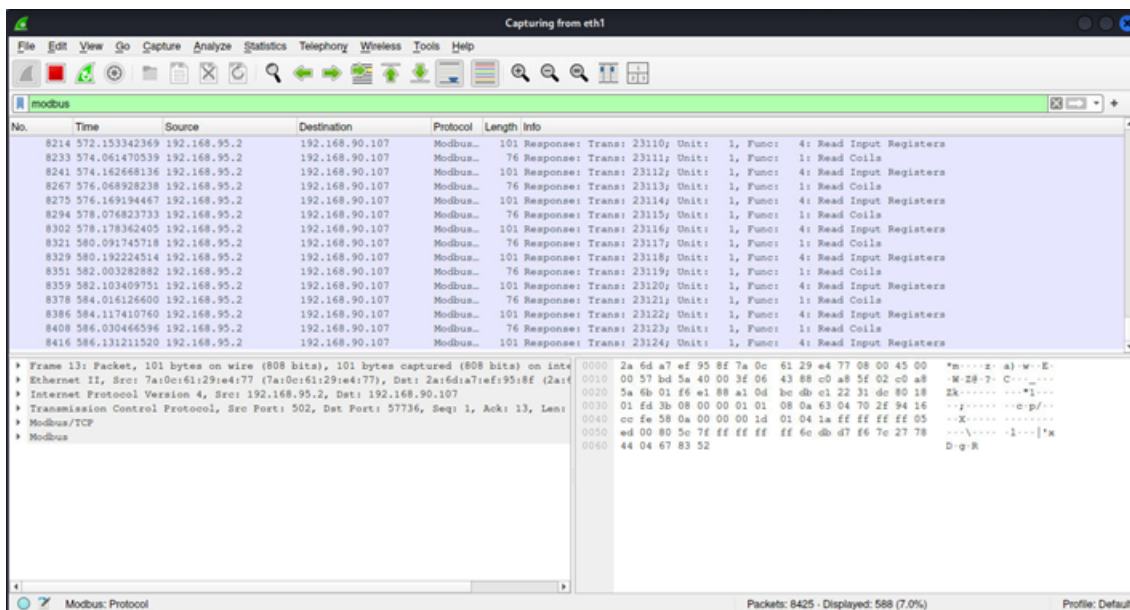
Una vez que se abra Wireshark, haz doble clic en la interfaz de red correspondiente (`eth1`) para comenzar a capturar el tráfico.

Habrà mucho tráfico, y lo primero que queremos hacer es verificar que la suplantación ARP se está realizando correctamente. Escribamos `arp` en la barra de filtro superior y pulsemos `Enter`.

Entonces veremos tráfico de red que indica que estamos enviando un mensaje que dice: «Hey, `192.168.90.107`». y también vemos nuestra dirección MAC, no la del HMI.

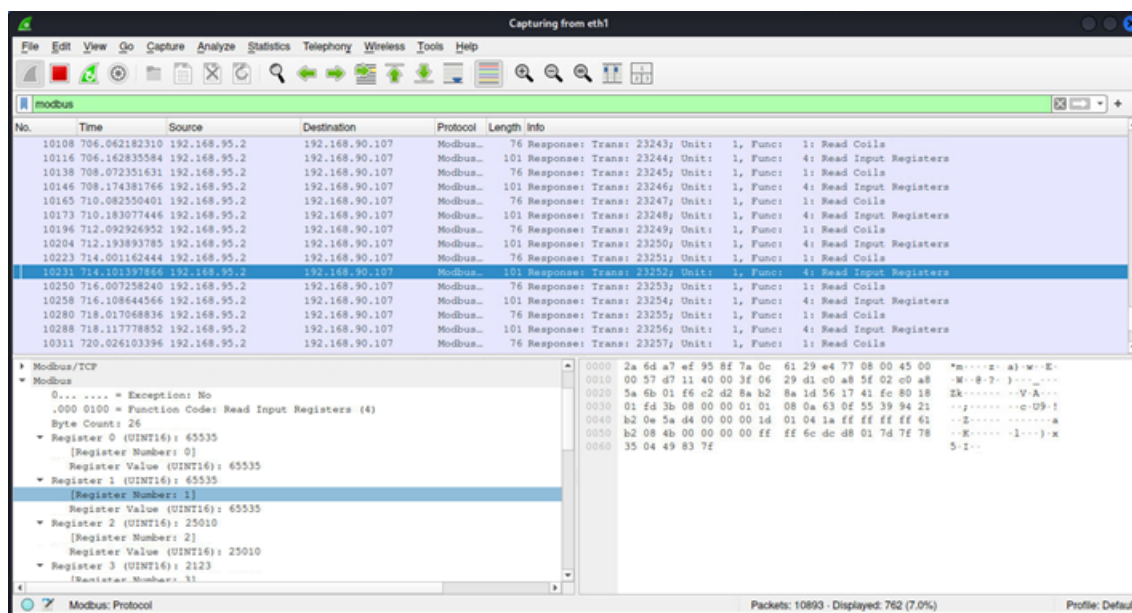


Wireshark tiene un filtro integrado que filtra solo el tráfico Modbus. Así que vamos a probarlo ahora: vamos a la barra de filtro de pantalla y cambiamos ARP por Modbus.



Podemos observar información interesante. Vemos que un dispositivo en la dirección 192.168.95.2 responde continuamente a las solicitudes de lectura de la interfaz hombre-máquina.

A partir de esta información, combinada con lo que encontramos durante el escaneo, podemos deducir que probablemente lo que está sucediendo es que la interfaz hombre-máquina está leyendo los registros de entrada y las bobinas del PLC. El PLC es el dispositivo en la posición 95.2. Si lo desea, puede hacer doble clic en cualquiera de estos paquetes para inspeccionarlos. También puede expandir la sección Modbus para ver los valores reales que se codifican en estos paquetes e intentar determinar cómo se corresponden estos valores con el estado físico del sistema de control industrial.



A veces, los operadores interactúan con la interfaz hombre-máquina (HMI). Y cuando realizamos este tipo de análisis y suplantación de identidad, podemos interceptar los paquetes de red resultantes. Y podríamos, posiblemente, aplicarles ingeniería inversa o reproducirlos para tomar el control del sistema de control industrial como deseemos, como atacantes. Como ejemplo, imaginemos que somos un operador interactuando con la HMI y veamos qué podemos observar desde la perspectiva del atacante.

Abre la estación de trabajo o workstation

Desde allí, abre un navegador web y accede a la URL <http://192.168.90.107:8080>, que es la dirección IP de la HMI, como ya hemos comentado. El puerto 8080 se usa normalmente para interfaces web cuando el puerto 80 no está disponible.

<http://192.168.90.107:8080>

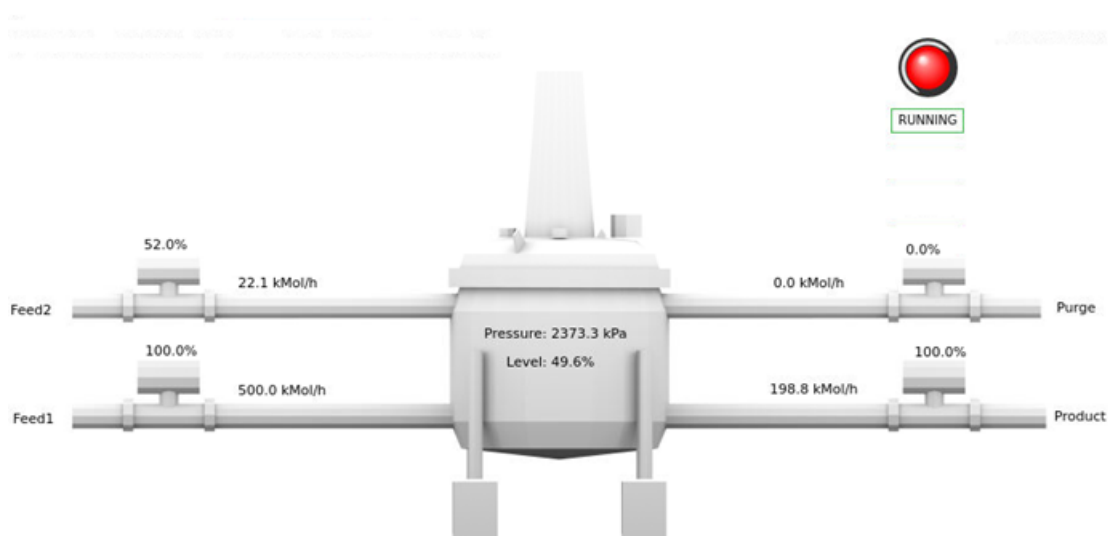
Este HMI LTS de Scada usa las credenciales predeterminadas: "admin" para el usuario y "admin" para la contraseña.

Acceda a la vista gráfica haciendo clic en el icono de la esquina superior izquierda que dice "Graphical Views".

Observará un botón parpadeante que dice RUNNING o "En ejecución".

Un operador puede pulsar este botón para detener el proceso. Vamos a hacerlo ahora para ver cómo se ve. Haga clic en "En ejecución" y el botón ahora dirá "Detenido". Si regresa al panel de control y observa la visualización, verá que hemos alcanzado un estado en el que la purga y el producto fluyen fuera del reactor, pero no se bombea nada para generar más producto.

Volvamos a la pestaña de la estación de trabajo y hagamos clic en "Detenido" nuevamente para reiniciar el proceso.



Ahora veamos si pudimos interceptar el tráfico de red que generó ese comando.

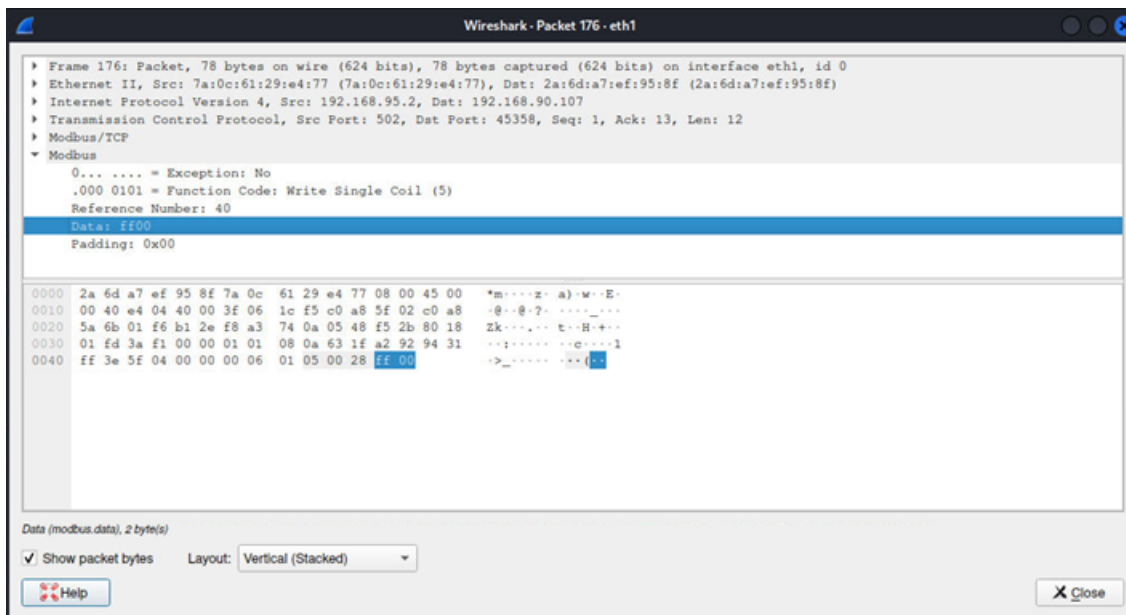
Vuelva a la pestaña de la estación de trabajo del atacante y abra Wireshark.

Puede escanear y ver si detecta algo diferente a los paquetes anteriores.

Se observa un único paquete de comando Write Single Coil

Haga doble clic para abrirlo.

Si expande la sección Modbus, podrá ver qué datos se envían para iniciar o detener el proceso.



Considere cómo podríamos usar la información que capturamos para falsificar un paquete con Scapy o Pi Modbus que potencialmente podría detener permanentemente el proceso de la planta química.

Fuente: <https://www.youtube.com/watch?v=1YB5mwc-2js>